

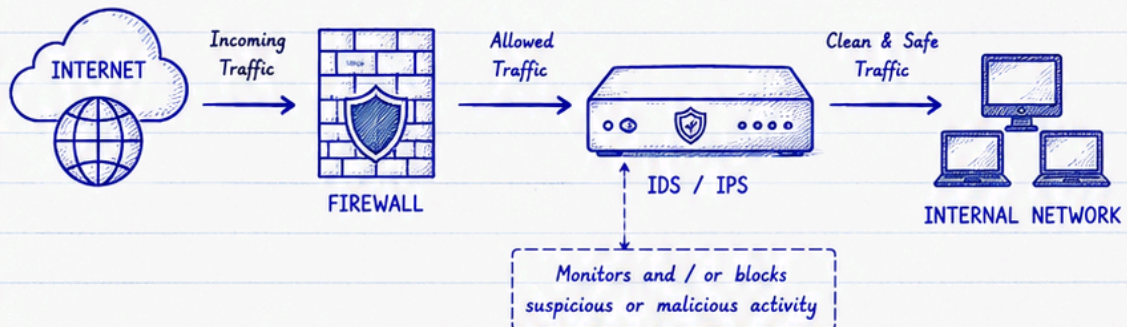
WHAT IS IDS & IPS?

Page 1 of 15

blueteamers.io

Intrusion Detection System & Intrusion Prevention System

NETWORK OVERVIEW



HOW IT WORKS

- * All traffic from the Internet passes through Firewall.
- * Allowed traffic is then inspected by IDS / IPS.
- * IDS detects and alerts the security team.
- * IPS can automatically block or prevent the attack.
- * Clean and safe traffic is then allowed into the internal network.

WHAT IS IDS?



- * IDS stands for Intrusion Detection System.
- * It is a passive security system.
- * It monitors network or host activity.
- * It detects suspicious or malicious behavior.
- * It generates alerts for the SOC / Analysts.
- * It does NOT block traffic.



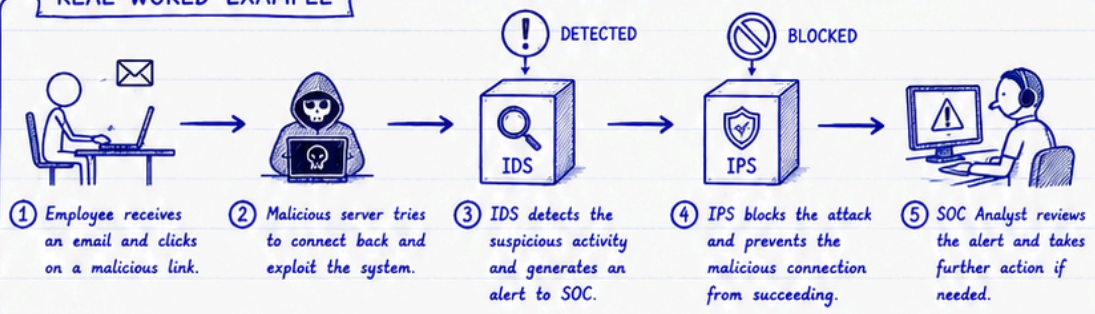
WHAT IS IPS?



- * IPS stands for Intrusion Prevention System.
- * It is an active security system.
- * It not only detects threats but also prevents them.
- * It can block malicious traffic automatically.
- * It helps stop attacks before they cause damage.



REAL-WORLD EXAMPLE



NOTES

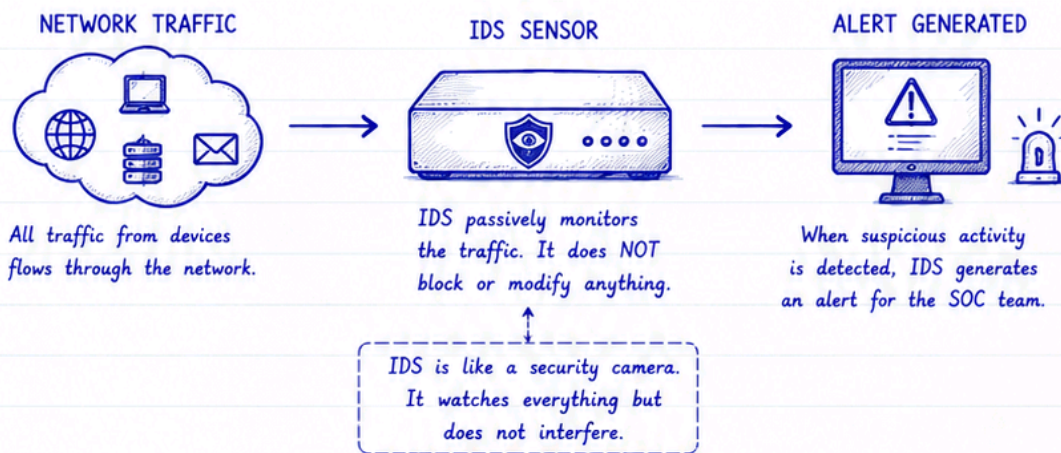
- * IDS = Detects and Alerts
- * IPS = Prevents and Blocks
- * Both IDS and IPS are critical for a strong defense.
- * IDS gives visibility, IPS provides protection.
- * Together, they help keep the organization safe.



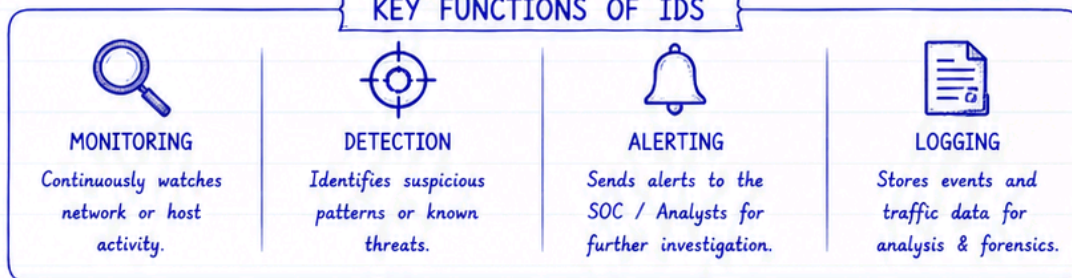
INTRUSION DETECTION SYSTEM (IDS)

An IDS is a passive security system that monitors network or host activity to detect suspicious or malicious behavior and generates alerts for the security team.

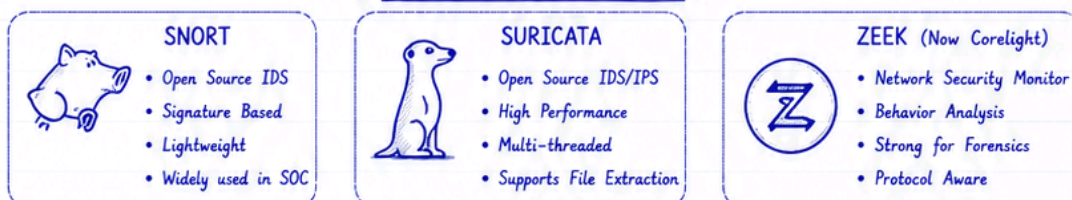
HOW IDS WORKS



KEY FUNCTIONS OF IDS



POPULAR IDS TOOLS



REAL-WORLD SOC EXAMPLE

Scenario: Detecting a Suspicious Port Scan

- 1 An attacker from 192.168.1.50 starts scanning multiple ports on the internal server.
- 2 IDS sensor sees unusual traffic pattern (many connection attempts in a short time).
- 3 IDS matches the behavior with a known rule (Port Scan Detection).
- 4 An alert is generated and sent to the SOC analyst.

ALERT LOG (Sample)

Timestamp : 2024-05-20 10:15:32
 Source IP : 192.168.1.50
 Destination IP : 10.0.0.25
 Protocol : TCP
 Destination Port : Multiple (1-1000)
 Signature ID : 1:122:6
 Alert : Possible Port Scan Detected
 Severity : Medium

SOC ANALYST ACTION

- Investigate the source IP
- Check logs & threat intel
- Block IP if malicious
- Document the incident

NOTES

- * IDS does not block traffic. It only detects and alerts.
- * It is an essential layer for visibility in the network.
- * All alerts should be reviewed and validated by analysts.
- * Proper tuning reduces false positives.



INTRUSION PREVENTION SYSTEM (IPS)

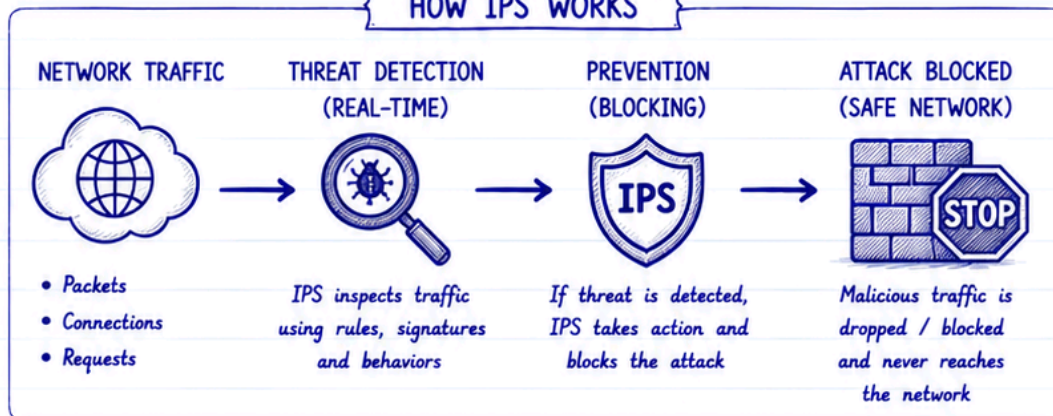
Page 3 of 15

blueteamers.io

WHAT IS IPS?

An Intrusion Prevention System (IPS) is an active security system that not only detects threats but also **prevents** and **blocks** them in real-time before they cause damage.

HOW IPS WORKS



IPS ACTIONS

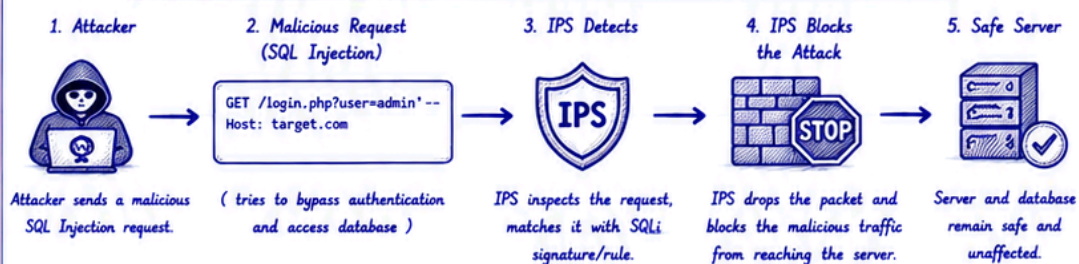
- ✓ Actively monitors traffic in real-time.
- ✓ Detects malicious patterns and behaviors.
- ✓ Drops packets that match attack signatures.
- ✓ Resets malicious connections.
- ✓ Blocks IP addresses or sources if needed.
- ✓ Protects the network and critical systems.



KEY CHARACTERISTICS

- ✓ Active Protection (Prevents attacks)
- ⌚ Real-Time Decision Making
- ⚙️ Traffic Blocking / Packet Dropping
- 👁️ Deep Packet Inspection (DPI)
- 📄 Signature, Anomaly & Policy Based

REAL-WORLD EXAMPLE - SQL INJECTION ATTACK BLOCKED BY IPS



EXAMPLE RULE (SQL INJECTION SIGNATURE)

```
alert tcp any any -> any any (
msg:"ET WEB_APPLICATION SQL Injection Attempt";
flow:to_server,established; content:"union select"; nocase;
sid:1000001; rev:1;)
```

↑ Action (Alert) ↑ What it Detects ↑ Direction of Traffic ↑ Pattern (Signature) ↑ Unique ID (SID)

IPS DEPLOYMENT POSITIONS

INLINE



(In-path blocking)
Stops traffic in real-time

PERIMETER



Protects internal network from external threats

INTERNAL



Protects critical systems inside the network

BENEFITS OF IPS

- * Prevents attacks before they cause damage.
- * Protects critical assets and sensitive data.
- * Reduces risk of successful breaches.
- * Works 24/7 in real-time.
- * Improves overall security posture.



NOTES

- * IPS is an active security control.
- * It can drop packets, reset connections or block IPs.
- * Proper tuning is important to avoid false positives.
- * IPS works best with IDS, Firewall and SIEM.
- * Together they create a strong defense.



★ Detect. Prevent. Protect. ★

IPS stops attacks before they succeed!

blueteamers.io

IDS VS IPS

Understanding the Difference



IDS (Intrusion Detection System)

A passive security system that monitors network or host activity and detects suspicious or malicious behavior, then generates alerts.

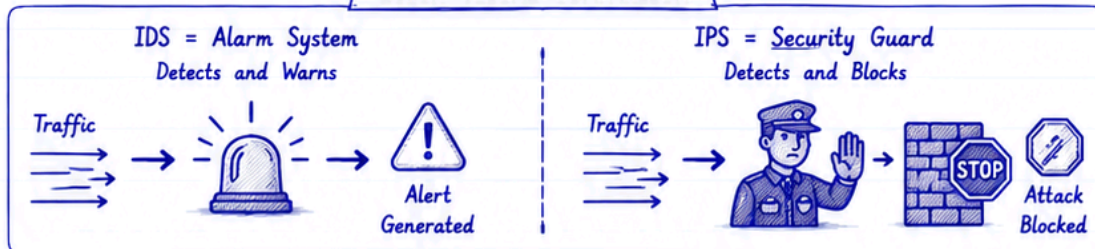


IPS (Intrusion Prevention System)

An active security system that not only detects threats but also takes action to prevent and block them in real-time.



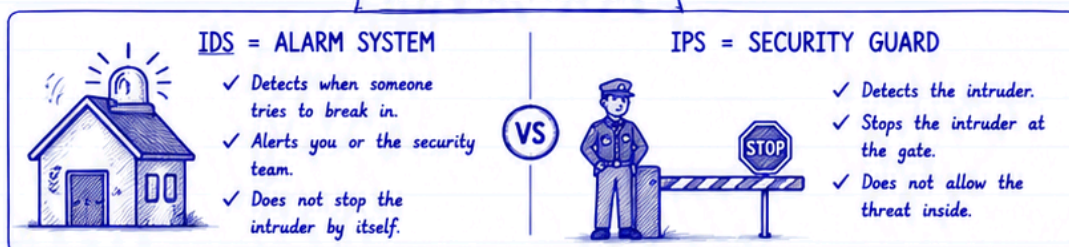
QUICK VISUAL COMPARISON



DETAILED COMPARISON TABLE

FEATURE	IDS	IPS
DETECTION	Detects suspicious or malicious activity.	Detects and prevents threats in real-time.
PREVENTION	Does NOT prevent attacks. (Only detects)	Actively prevents and blocks attacks.
ALERTING	Generates alerts for SOC analysts.	May generate alerts, but primary goal is to block.
TRAFFIC FLOW	Traffic is allowed to pass (Does not interfere).	Traffic is inspected and malicious traffic is blocked or dropped.
PLACEMENT	Usually placed after firewall (Monitoring mode).	Usually placed inline (Between users and network).
RESPONSE TIME	Time after detection (Alert is generated).	Real-time response (Block happens immediately).
PRIMARY GOAL	Visibility and Detection	Prevention and Protection
EXAMPLES	• Snort (IDS mode) • Suricata (IDS mode) • Zeek • OSSEC	• Snort (IPS mode) • Suricata (IPS mode) • Palo Alto IPS • Cisco IPS
IMPACT ON NETWORK	No impact on traffic (Passive).	May impact performance due to inline blocking.

REAL-WORLD ANALOGY



NOTES

- * IDS gives you visibility.
- * IPS gives you protection.
- * Best security = IDS + IPS working together.
- * Always review alerts and tune rules to reduce false positives.
- * Placement and proper configuration are critical for both systems.



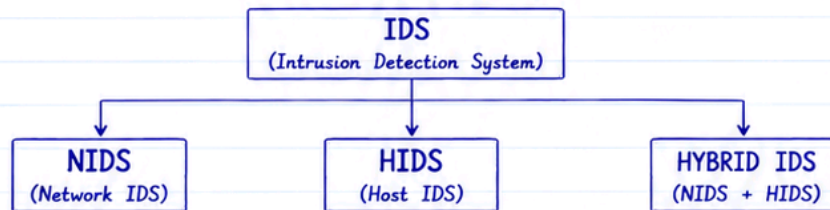
TYPES OF IDS

Intrusion Detection System - Different Types

OVERVIEW

IDS can be deployed in different ways depending on what is being monitored.

There are three main types of IDS.



1) NETWORK INTRUSION DETECTION SYSTEM (NIDS)

NIDS monitors network traffic flowing across the network for suspicious or malicious activities.

- Works at the network level (Layer 2-7)
- Monitors packets, sessions and protocols
- Deployed on network devices
- Does NOT monitor individual host

Placement

At a strategic point in the network



How it Works



Alert to SOC

Real-World Example

If an attacker performs a port scan from outside, NIDS will detect unusual traffic patterns and generate an alert.

Example Tools

- Snort
- Suricata
- Zeek (Bro)
- Security Onion



2) HOST INTRUSION DETECTION SYSTEM (HIDS)

HIDS monitors activities on a specific host or server.

- Works at the host level
- Monitors system logs, file integrity, user activities, processes, registry
- Installed on individual hosts
- Detects attacks that target the host

Placement



How it Works

Host Activities (Logs, Files, Processes)



HIDS Agent

Alert to SOC

Real-World Example

If malware modifies a system file or a suspicious user logs in locally, HIDS will detect and alert.

Example Tools

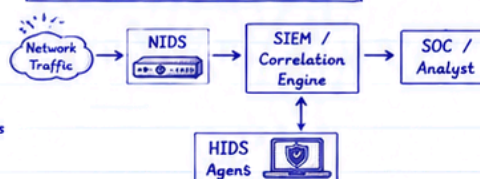
- OSSEC
- Wazuh
- Tripwire
- Sysmon



3) HYBRID IDS (NIDS + HIDS)

Hybrid IDS combines both NIDS and HIDS for complete visibility.

- Monitors both network and host
- Provides better detection coverage
- Correlates alerts from both sources
- Ideal for enterprise environments



Real-World Example

An attacker exploits a vulnerability (detected by NIDS) and then tries to escalate privileges on the host (detected by HIDS). Both alerts are correlated.

COMPARISON TABLE

Feature	NIDS	HIDS	Hybrid IDS
Monitors	Network Traffic	Host / System	Both Network & Host
Deployment	Network Devices	On Individual Hosts	Both Network & Hosts
Layer	Layer 2 - 7	OS / Application Layer	All Layers
Detects	Scans, Attacks, Exploits	Malware, File Changes, User Activity	All Types of Threats
Visibility	High (Network Wide)	Limited (Single Host)	Complete Visibility
Example Tools	Snort, Suricata, Zeek	OSSEC, Wazuh, Tripwire	Suricata + OSSEC, Wazuh
Best For	Perimeter & Network Monitoring	Server & Endpoint Monitoring	Enterprise Security

KEY TAKEAWAYS

- * NIDS = Watches the network.
- * HIDS = Watches the host.
- * Hybrid IDS = Watches everything (Network + Host).
- * Using all together gives the best security posture.



SIGNATURE-BASED DETECTION

Page 6 of 15

blueteamers.io

Signature-based detection identifies threats by matching network traffic or host activity against a database of **known attack patterns** (signatures).

HOW IT WORKS

1) KNOWN ATTACK



An attacker uses a known malware, exploit or technique.

2) SIGNATURE MATCH



IDS compares the traffic or activity with its signature database.

3) ALERT GENERATED



If a match is found, an alert is generated and sent to the SOC.

WHAT IS A SIGNATURE?

- A signature is a unique pattern that represents a known threat.
- It can be based on:
 - ✓ Malware hash (MD5, SHA1, SHA256)
 - ✓ IP address or domain
 - ✓ Exploit code or shellcode
 - ✓ Packet content or behavior pattern
- Signatures are created by security researchers, vendors and threat intelligence teams.



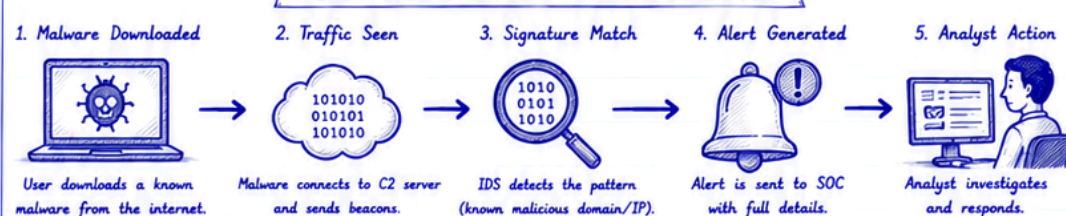
EXAMPLES OF SIGNATURES

Type	Example (Signature)
Malware Hash	MD5: d41d8cd98f00b204e9800998ecf8427e
IP Address	192.168.100.50
Domain	badmalicious.com
Exploit Pattern	content: "/etc/passwd" in HTTP URI
Shellcode Pattern	90 90 90 90 90 E8 ?? ?? ?? ??
Behavior Pattern	Port scan → Multiple failed logins

SIGNATURE-BASED DETECTION WORKFLOW



REAL-WORLD EXAMPLE - MALWARE DETECTION



EXAMPLE: SNORT SIGNATURE (MALWARE TRAFFIC)

```
alert tcp any any -> any 80 (msg:"ET MALWARE C2 Activity Detected";  
flow:established,to_server; content: "/malicious"; http_uri; content: "User-Agent|3a|badbot";  
nocase; sid:2101001; rev:2;)
```

↑ ↑ ↑ ↑ ↑ ↑ ↑
Action Protocol Source → Message Traffic Flow Pattern to Match Additional Signature ID
(Alert) (TCP) Destination (Alert Text) Direction (/malicious in URI) Pattern & Revision
Port

ADVANTAGES

- ✓ High accuracy for known threats.
- ✓ Low false positive rate.
- ✓ Fast detection and response.
- ✓ Easy to implement and tune.
- * Effective against common attacks.



LIMITATIONS

- ✗ Cannot detect unknown (zero-day) threats.
- ✗ Requires frequent signature updates.
- ✗ Less effective against new or mutated malware.
- ✗ May miss fileless or advanced attacks.



NOTES

- * Signature-based detection is best for known threats.
- * Regular updates are critical for effectiveness.
- * Works best when combined with anomaly-based detection.
- * Always review alerts and validate before responding.



USE CASES

- * Malware detection
- * Intrusion detection
- * Web attack detection
- * Policy violation detection
- * Threat intelligence matching



★ Know the pattern. Stop the threat. ★

blueteamers.io

ANOMALY-BASED DETECTION

Page 7 of 15

blueteamers.io

Anomaly-based detection identifies threats by analyzing behavior and finding deviations from what is considered "normal".

HOW IT WORKS

1) NORMAL BEHAVIOR



System learns what is normal over time (users, traffic, processes, etc.).

2) UNUSUAL ACTIVITY



A behavior deviates from the baseline (unusual patterns, volume, time, location).

3) ALERT GENERATED



The system generates an alert because the activity looks suspicious.

WHAT IS ANOMALY?

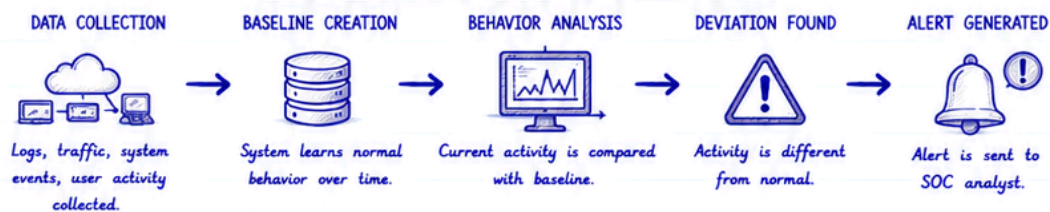
- An anomaly is any activity that does not follow the normal or expected pattern.
- It does not depend on known signatures.
- It uses machine learning, statistics or behavior profiling.
- It can detect zero-day attacks and insider threats.



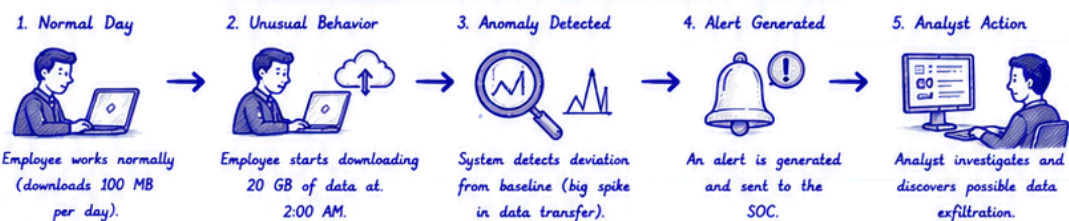
EXAMPLES OF ANOMALIES

User Behavior	User logs in from a new country at 3 AM
Network Traffic	Sudden spike in outbound data to an unknown IP
File Activity	Mass deletion or modification of files
Process Behavior	Unknown process spawned by system
Authentication	Multiple failed logins from a single account

ANOMALY-BASED DETECTION WORKFLOW



REAL-WORLD EXAMPLE - INSIDER DATA EXFILTRATION



EXAMPLE: SURICATA ANOMALY ALERT (Using Thresholding / EVE JSON)

```
{ "timestamp": "2024-05-07T02:13:45.123456+0000", "event_type": "alert",  
  "src_ip": "192.168.10.50", "dest_ip": "185.220.101.25", "proto": "TCP", "dest_port": 443,  
  "alert": { "action": "allowed", "gid": 1, "signature_id": 1000001,  
    "rev": 1, "signature": "ET ANOMALY Outbound Data Transfer Detected",  
    "severity": 2, "category": "Anomaly Attempt", "bytes": 21474836480, "flow_id": 1234567890 }
```

Time of Alert Source IP (Internal Host) Destination IP (External Host) Signature Name (Anomaly Detected) Total Data Transferred (20 GB) Severity Level

COMMON ANOMALY TECHNIQUES

- Statistical Analysis
- Machine Learning
- Behavioral Profiling
- Thresholding
- Time-based Analysis
- Peer Group Analysis



ADVANTAGES

- ✓ Detects unknown / zero-day threats.
- ✓ Finds insider threats effectively.
- ✓ Not dependent on signatures.
- ✓ Learns environment automatically.
- ✓ Strong against advanced attackers.



LIMITATIONS

- ✗ Higher false positive rate.
- ✗ Needs time to learn baseline.
- ✗ Resource intensive.
- ✗ May flag legitimate changes.
- ✗ Requires tuning and maintenance.

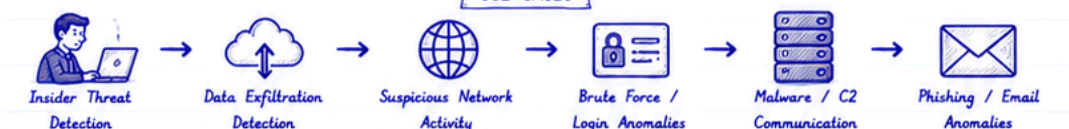


NOTES

- * Baseline must be accurate.
- * Environment changes need regular re-learning.
- * Works best when combined with other detection methods (IDS, firewall, EDR).



USE CASES



Normal is the baseline. Deviation is the danger.



blueteamers.io

INTRODUCTION TO SURICATA

Page 8 of 15

blueteamers.io

Suricata is a high performance, open source Network Intrusion Detection System (NIDS) and Intrusion Prevention System (IPS) engine.

WHAT IS SURICATA?

- Suricata is an open source IDS/IPS/NSM engine developed by the OISF (Open Information Security Foundation).
- It inspects network traffic in real-time and generates alerts for suspicious or malicious activity.
- It can run in IDS mode (passive monitoring) or IPS mode (inline blocking).
- It understands common protocols and supports thousands of detection rules.

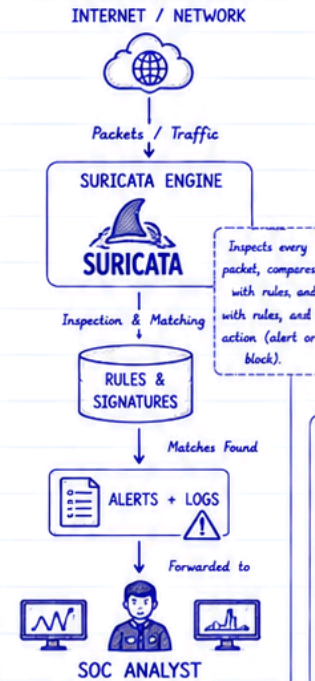


SURICATA

KEY CAPABILITIES

- Protocol Detection
- File Extraction
- SSL/TLS Decryption Support
- Multi-threaded Architecture
- Powerful Rule Engine
- Alerting in Multiple Formats (EVE JSON, Fast Log, Syslog)

HOW SURICATA WORKS



IDS VS IPS MODE

IDS MODE (Passive)

- Monitors traffic
- Does not block
- Only generates alerts



IPS MODE (Inline)

- Monitors traffic
- Blocks malicious traffic
- Takes action in real-time



WHY SOC TEAMS USE SURICATA?

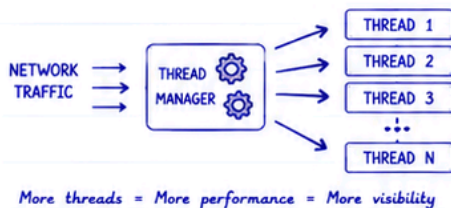
- ✓ Open source and free
- ✓ High performance & multi-threaded
- ✓ Supports IDS, IPS and NSM
- ✓ Large and active community
- ✓ Works on Windows, Linux, BSD
- ✓ Integrates with SIEM (ELK, Splunk, Wazuh)
- ✓ Custom rule creation support

SURICATA ARCHITECTURE (HIGH LEVEL)



MULTI-THREADING (PERFORMANCE)

- Suricata is built for speed.
- It uses multiple threads to process traffic in parallel.
- Each thread handles a flow (or packet set), improving performance on high speed networks.



HIGH PERFORMANCE DETECTION

- Suricata is designed to handle 10 Gbps+ traffic.
- Uses memory efficient data structures.
- Supports hardware offloading (AF_PACKET, PF_RING, DPDK).
- Performs deep inspection with minimal performance impact.

PERFORMANCE FEATURES

- ✓ Zero-copy packet capture
- ✓ Lock-free queues
- ✓ Threaded detection engine
- ✓ Efficient memory management
- ✓ Optimized rule matching (AC/Boyer-Moore)



Built for High Speed Networks

CHECK SURICATA VERSION & BUILD INFO

```
kali@kali:~$ suricata --build-info
This is Suricata version 7.0.6 RELEASE running in SYSTEM
Features:
- NFQUEUE support: yes
- AF_PACKET support: yes
- PCAP support: yes
- HAVE_LIBJANSSON: yes
- HAVE_LIBCAP_NG: yes
- PCRE JIT enabled: yes
- LINUX SLL enabled: yes
- Libnet support: yes
- Rust support (app-layer): yes
kali@kali:~$
```

Run this command on your system to see Suricata version and compiled features.

BUILD INFO EXPLAINED

1. Version
Shows the installed Suricata version.
2. Running Mode
SYSTEM mode = Full IDS/IPS functionality.
3. Features
Lists all enabled features and libraries.
4. JIT / Rust / Libnet
Important for performance and protocol detection.
5. If any feature is "no", some capabilities may be limited.



NOTES

- * Suricata is one of the most widely used IDS/IPS engines in the world.
- * It gives deep visibility into network traffic and generates high quality alerts.
- * It is the backbone of many SOC, XDR and threat hunting tools.
- * Mastering Suricata is a must for every Blue Team / SOC Analyst.



SURICATA RULES EXPLAINED

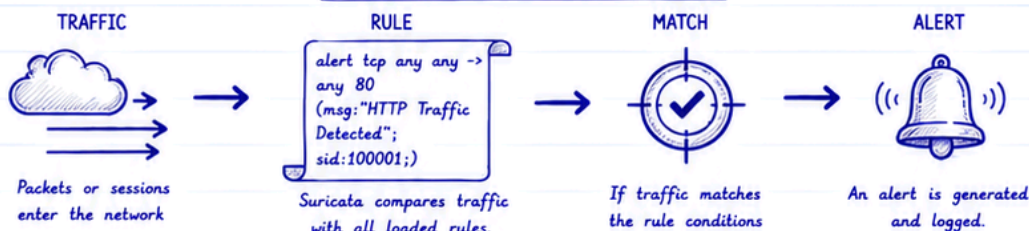
Page 9 of 15

blueteamers.io

Suricata uses rules to identify and alert on malicious or suspicious activity.

Rules are the **heart** of signature-based detection.

HOW A SURICATA RULE WORKS



ANATOMY OF A SURICATA RULE

EXAMPLE RULE:

"alert tcp any any -> any 80 (msg:"HTTP Traffic Detected"; sid:100001; rev:1;)"

alert	tcp	any	any	->	any	80	(msg; sid; rev;)
Action keyword. Tells Suricata what to do when a match is found. (alert, drop, pass, log)	Protocol. Can be: tcp, udp, icmp, ip, http, tls, etc.	Source IP address. Can be an IP, network, port, or any. (any = all)	Source Port. Can be a specific port, range, or any.	Direction. Traffic flow from source to destination.	Destination IP address. Can be an IP, network, or any.	Destination Port. Here: HTTP service port.	Rule options (metadata). - msg = message - sid = rule ID - rev = revision number
	Examples: - tcp - udp - icmp	Examples: - any 192.168.1.0/24 ['!']10.0.0.5	Examples: - any 80 1024:65535		Examples: - any 10.0.0.0/8 ['!']192.168.1.5	Examples: 80 (HTTP) 443 (HTTPS) 22 (SSH)	

COMMON RULE OPTIONS (INSIDE PARENTHESES)

msg: Human readable message
sid: Unique Signature ID
rev: Revision number
classtype: Classification (policy, trojan, scan, etc.)
priority: Alert priority (1 = highest)

content: Match specific content in payload
nocase: Case insensitive content match
http-uri: Match URI in HTTP traffic
flow: Define the flow (to_server, to_client)
pcre: Use regular expressions

Example with more options:
alert tcp any any -> any 80 (msg:"Possible SQLi Attempt"; content:"union select"; nocase; http-uri; classtype:web-application-attack; sid:100002; rev:1;)

SURICATA RULE FILE (EXAMPLE)

/etc/suricata/rules/local.rules

```
1 # Custom Rules
2 alert tcp any any -> any 22 (msg:"SSH Connection Detected"; sid:100000; rev:1;)
3 alert tcp any any -> any 80 (msg:"HTTP Traffic Detected"; sid:100001; rev:1;)
4 alert tcp any any -> any 443 (msg:"HTTPS Traffic Detected"; sid:100002; rev:1;)
5 alert icmp any any -> any any (msg:"ICMP PING Detected"; sid:100003; rev:1;)
6 alert tcp any any -> any any (msg:"Possible Port Scan"; flags:S;
7 threshold:type threshold, track by_src, count 10, seconds 60; sid:100004; rev:1;)
```

EXPLANATION

Line 2 : Detects SSH traffic on port 22
Line 3 : Detects HTTP traffic on port 80
Line 4 : Detects HTTPS traffic on port 443
Line 5 : Detects ICMP ping requests
Line 6-7 : Detects Port Scan (10 SYN packets from same IP in 60 seconds)

REAL-WORLD EXAMPLE

Detecting HTTP Traffic



Attacker/ User
10.0.0.5

HTTP Request



Web Server
10.0.0.10:80

Rule Used:
alert tcp any any -> any 80 (msg:"HTTP Traffic Detected"; sid:100001; rev:1;)

What Happens?

- ✓ Suricata inspects the packet.
- ✓ Rule matches because destination port is 80.
- ✓ Alert is generated with rule SID 100001.
- ✓ SOC Analyst reviews the alert.



TESTING A RULE (QUICK CHECK)

1. Validate rule syntax

```
kali@kali:~$ suricata -T -c /etc/suricata/suricata.yaml
23/05/12-10:30:15 <Info> -- Rule loaded successfully.
23/05/12-10:30:15 <Info> -- 1 rule(s) processed.
23/05/12-10:30:15 <Info> -- Rules OK.
```



2. Reload Suricata rules

```
kali@kali:~$ sudo suricata -c /etc/suricata/suricata.yaml -q 0
```

3. Watch alerts in real-time (eve.json)

```
kali@kali:~$ tail -f /var/log/suricata/eve.json
```

When traffic matches, you will see alerts in eve.json

NOTES

- * Rules define what Suricata looks for.
- * Good rules = Good detection.
- * Always keep rules updated.
- * Test every rule before deploying.
- * Review and tune rules to reduce false positives.



TIP



Start simple. Understand each part of the rule. Then build advanced detection rules.



Good rules find threats. Great analysts understand them.



blueteamers.io

READING ALERTS LIKE A SOC ANALYST

Page 10 of 15

blueteamers.io

Suricata generates alerts when traffic matches a rule. Understanding alert fields helps a SOC analyst investigate and respond quickly.

ALERT WORKFLOW



WHAT IS EVE.JSON?

- Suricata logs alerts and events in JSON format (eve.json).
- Easy to parse and integrate with SIEM tools.
- Contains rich details about each event.

{ ... }

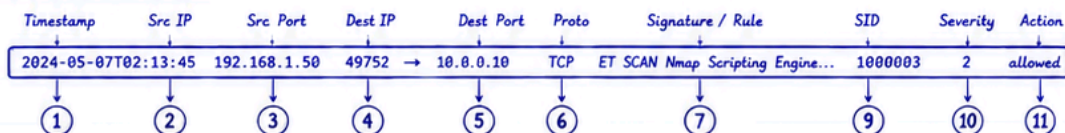
EXAMPLE ALERT (eve.json)

```
1 {
2   "timestamp": "2024-05-07T02:13:45.123456+0000",
3   "flow_id": 1234567890123456,
4   "event_type": "alert",
5   "src_ip": "192.168.1.50",
6   "src_port": 49752,
7   "dest_ip": "10.0.0.10",
8   "dest_port": 22,
9   "proto": "TCP",
10  "alert": {
11    "action": "allowed",
12    "gid": 1,
13    "signature_id": 1000003,
14    "rev": 1,
15    "signature": "ET SCAN Nmap Scripting Engine User-Agent Detected",
16    "category": "Attempted Information Leak",
17    "severity": 2
18  },
19  "flow": {
20    "state": "established",
21    "pkts_toserver": 4, "pkts_toclient": 2,
22    "bytes_toserver": 384, "bytes_toclient": 120
23  }
24 }
```

UNDERSTANDING EACH FIELD

- 1 Timestamp
When the alert was generated (UTC time).
- 2 Source IP
IP address of the system that initiated the connection.
- 3 Source Port
Port number used by the source.
- 4 Destination IP
IP address of the target host.
- 5 Destination Port
Port number of the target service.
- 6 Protocol
Network protocol used (TCP, UDP, ICMP, etc.).
- 7 Signature / Rule Name
The rule name that triggered the alert.
- 8 Signature ID (SID)
Unique ID of the rule that matched.
- 9 Category
The type of threat or activity.
- 10 Severity
Indicates how serious the alert is (1 = Low, 4 = High).
- 11 Action
What Suricata did (allowed / blocked / dropped).

FIELD MAP (VISUAL)



REAL-WORLD EXAMPLE - NMAP SCAN DETECTION

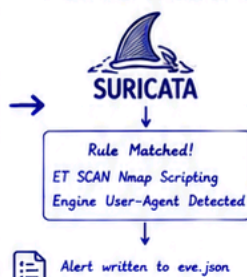
1. ATTACKER (KALI) RUNS NMAP SCAN

```
kali@kali:~$ nmap -sS -sV 10.0.0.10
Starting Nmap 7.94 at 2024-05-07 02:13 UTC
Nmap scan report for 10.0.0.10
Host is up (0.00033s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1
80/tcp    open  httpd    Apache/2.4.41
443/tcp   open  https    nginx/1.18.0

Nmap done: 1 IP address (1 host up) scanned in 2.45 seconds
```

2. SURICATA GENERATES ALERT



3. ALERT VIEWED BY ANALYST

```
Timestamp : 2024-05-07T02:13:45
Src IP    : 192.168.1.50
Src Port  : 49752
Dest IP   : 10.0.0.10
Dest Port : 22
Proto     : TCP
Signature : ET SCAN Nmap Scripting Engine User-Agent Detected
SID       : 1000003
Severity  : 2 (Medium)
Action    : allowed
```

ALERT SEVERITY LEVELS (SURICATA)

Severity	Level	Description
1	Low	Low risk activity
2	Medium	Potentially suspicious
3	High	Likely malicious activity
4	Critical	Critical threat / Attack

COMMON EVENT TYPES

- alert → Rule matched
- http → HTTP transaction
- dns → DNS query/response
- tls → TLS/SSL activity
- fileinfo → File extraction info
- flow → Flow session info
- dropped → Packet dropped

TIPS FOR ANALYSTS

- ✓ Check source IP reputation.
- ✓ Validate destination and port.
- ✓ Review rule name and severity.
- ✓ Correlate with other alerts.
- ✓ Look for patterns and repeats.

NOTES

- * Alerts are only useful when you understand them.
- * Always validate before escalating.
- * Context is everything: Who, What, When, Where, Why.
- * Good analysts read alerts. Great analysts understand stories behind alerts.

TOOLS THAT USE EVE.JSON

- ELK Stack (Elasticsearch, Logstash, Kibana)
- Splunk
- Wazuh
- Security Onion
- Custom Python / Scripts

☆ Every alert tells a story. Your job is to understand it. ☆

blueteamers.io

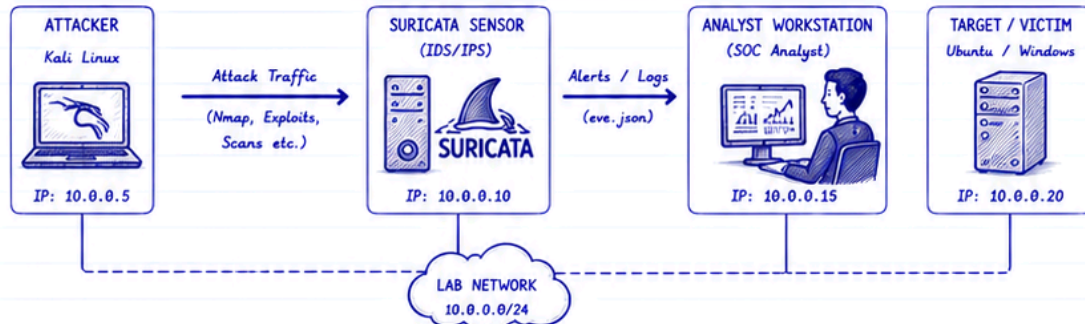
IDS/IPS PROJECT SETUP

Page 11 of 15

blueteamers.io

In this project, we will build a simple lab to detect and alert on malicious activity using Suricata IDS/IPS. This lab will simulate a real SOC environment.

LAB ARCHITECTURE OVERVIEW



COMPONENTS EXPLAINED

- 1 Attacker (Kali Linux)**
 - Used to perform scans, exploits and attacks.
 - Example tools: Nmap, Nikto, Hydra, etc.
- 2 Suricata Sensor**
 - Monitors all traffic in the network.
 - Detects threats and generates alerts.
- 3 Analyst Workstation**
 - SOC Analyst reviews alerts and investigates.
 - Tools: jq, less, vim, Wireshark, ELK (optional).
- 4 Target / Victim**
 - A system that can be attacked.
 - Can be a vulnerable machine or DVWA / Metasploitable.

GOAL OF THE PROJECT

- ✓ Deploy Suricata IDS.
- ✓ Capture and monitor network traffic.
- ✓ Generate and analyze alerts.
- ✓ Detect Nmap scans (and other attacks).
- ✓ Investigate alerts like a SOC Analyst.
- ✓ Document findings and respond.

NETWORK DETAILS

Network	: 10.0.0./24
Gateway	: 10.0.0.1
Suricata (Sensor)	: 10.0.0.10
Kali (Attacker)	: 10.0.0.5
Analyst (SOC)	: 10.0.0.15
Target (Victim)	: 10.0.0.20

SYSTEM ROLES & IP SUMMARY

System	Role	IP Address	OS	Purpose
Kali Linux	Attacker	10.0.0.5	Kali Linux	Generate attack traffic (scans, exploits)
Suricata Sensor	IDS/IPS	10.0.0.10	Ubuntu / Debian	Detect threats and generate alerts
Analyst Workstation	SOC Analyst	10.0.0.15	Ubuntu / Windows	Analyze alerts and investigate
Target / Victim	Target	10.0.0.20	Ubuntu / Windows	Be the target of attacks

QUICK SETUP CHECKLIST



- ✓ All VMs created and running.
- ✓ Network configured (Host-Only / Internal Network).
- ✓ IP addresses assigned and tested (ping).
- ✓ Suricata installed and running on sensor.
- ✓ eve.json logging enabled.
- ✓ Alerts visible and being generated.

VERIFY CONNECTIVITY (PING TEST)

```
kali@kali:~$ ping 10.0.0.10
PING 10.0.0.10 (10.0.0.10) 56(84) bytes of data:
64 bytes from 10.0.0.10: icmp_seq=1 ttl=64 time=0.386 ms
64 bytes from 10.0.0.10: icmp_seq=2 ttl=64 time=0.297 ms
64 bytes from 10.0.0.10: icmp_seq=3 ttl=64 time=0.267 ms
^C
--- 10.0.0.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 0.267/0.316/0.386/0.049 ms
```

SURICATA INSTALLATION & START (UBUNTU / DEBIAN)

1. INSTALL SURICATA

```
sudo apt update
sudo apt install suricata -y
suricata --build-info | head -n 10

# Check version
suricata -V
```



2. EDIT CONFIG (IF NEEDED)

```
sudo nano /etc/suricata/suricata.yaml
```

- Set HOME_NET: "[10.0.0.0/24]"
- Set EXTERNAL_NET: "any"
- Enable eve-log:
 - eve-log:
 - enabled: yes
 - filetype: regular
 - filename: eve.json



3. START SURICATA (IDS MODE)

```
sudo systemctl enable suricata
sudo systemctl start suricata
sudo systemctl status suricata --no-pager

# Follow alerts in real-time
sudo tail -f /var/log/suricata/eve.json
```



IMPORTATT DIRECTORIES & FILES



- /etc/suricata/suricata.yaml → Main configuration file
- /etc/suricata/rules/ → Rule files directory
- /var/log/suricata/eve.json → Alerts in JSON format
- /var/log/suricata/suricata.log → Engine log file

LAB RULES (EXAMPLE)

We will use Emerging Threats rules (ET Open). They are included by default in Suricata.

Rule path: /etc/suricata/rules/



NOTES

- ★ This is a lab environment for learning and practice.
- ★ Never run attacks on systems you do not own or without permission.
- ★ Always document your findings.
- ★ Good labs build strong analysts!



TIP

Keep your lab clean and organized. Take screenshots and notes for each step.



★ Build the lab. Generate the traffic. Detect the threats. ★

blueteamers.io

In this part, we will run Nmap scans from the attacker machine and detect them using Suricata rules. Suricata will generate alerts for our SOC.

PROJECT WORKFLOW



WHAT WE ARE DETECTING?

- Port Scans
- Service Discovery
- OS Detection Attempts
- Nmap Default Scripts
- Suspicious Reconnaissance



ATTACKER ACTIVITY - NMAP SCAN

```

kali@kali:~$ nmap -sS -sV 10.0.0.20
Starting Nmap 7.94 at 2024-05-07 02:20 UTC
Nmap scan report for 10.0.0.20
Host is up (0.00033s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
443/tcp   open  https    nginx 1.18.0 (Ubuntu)
3306/tcp  open  mysql    MySQL 5.7.37-0ubuntu0.18.04.1
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap done: 1 IP address (1 host up) scanned in 3.45 seconds
kali@kali:~$
  
```

SCAN DETAILS EXPLAINED

- 1 Target IP : 10.0.0.20
- 2 Scan Type : -sS (TCP SYN scan)
- 3 Service Version Detection : -sV
- 4 Open Ports Found : 22, 80, 443, 3306
- 5 Services Detected : SSH, HTTP, HTTPS, MySQL
- 6 Scan Duration : 3.45 seconds



Why it matters?

Attackers use Nmap to discover open ports, services and vulnerabilities before launching an attack.

SURICATA ALERT GENERATED (evee.json)

```

1 {
2   "timestamp": "2024-05-07T02:20:15.123456+0000",
3   "flow_id": 1234567890123456,
4   "event_type": "alert",
5   "src_ip": "10.0.0.5",
6   "src_port": 49752,
7   "dest_ip": "10.0.0.20",
8   "dest_port": 22,
9   "proto": "TCP",
10  "alert": {
11    "action": "allowed",
12    "gid": 1,
13    "signature_id": 1000003,
14    "rev": 1,
15    "signature": "ET SCAN Nmap Scripting Engine User-Agent Detected",
16    "category": "Attempted Information Leak",
17    "severity": 2
18  }
19 }
  
```

ALERT FIELD EXPLANATION

- 1 Timestamp : When the alert was generated (UTC time).
- 2 Flow ID : Unique ID of the network flow.
- 3 Event Type : alert = Suricata generated an alert.
- 4 Source IP : IP of the attacker (10.0.0.5).
- 5 Source Port : Port used by the attacker.
- 6 Destination IP : IP of the target host (10.0.0.20).
- 7 Destination Port : Port being scanned (22 in this case).
- 8 Protocol : TCP (most Nmap scans use TCP).
- 9 Signature ID : Rule ID that matched (1000003).
- 10 Signature Name : Name of the rule that matched.
- 11 Category : Type of activity (Information Leak).
- 12 Severity : 2 = Medium (1 Low, 2 Medium, 3 High, 4 Critical).
- 13 Action : allowed (logged but not blocked - IDS mode).

RULE THAT TRIGGERED THE ALERT

```

alert tcp any any -> any any (msg:"ET SCAN Nmap Scripting Engine User-Agent Detected";
flow:to_server,established; content:"Nmap Scripting Engine"; http.user_agent; classtype:attempted-info;
sid:1000003; rev:1;)
  
```

Action Protocol Direction Message Content to match Field Category Rule ID Revision

WHY THIS RULE MATCHED?

- ☒ Nmap sends a User-Agent: "Nmap Scripting Engine"
- ☒ Suricata inspects HTTP headers
- ☒ Rule looks for that pattern
- ☒ Match found -> Alert generated



ALERTS IN REAL-TIME (LIVE VIEW)

```

kali@kali:~$ tail -f /var/log/suricata/evee.json
{
  "event_type": "alert",
  "timestamp": "2024-05-07T02:20:15.123456+0000",
  "src_ip": "10.0.0.5",
  "dest_ip": "10.0.0.20",
  "signature": "ET SCAN Nmap Scripting Engine User-Agent Detected",
  "signature_id": 1000003,
  "severity": 2
}
...
  
```

ANALYST OBSERVATION

- Source IP (10.0.0.5) is scanning the target.
- Multiple ports were scanned in a short time.
- Rule matched is related to Nmap User-Agent.
- This is reconnaissance activity.

What should the analyst do next?

- ☒ Check for repeated scans
- ☒ Correlate with other alerts
- ☒ Check firewall / EDR logs
- ☒ Decide if response is needed

TOOLS USED

- Nmap (Attacker)
- Suricata (Sensor)
- evee.json (Logs)
- SOC Analyst

NOTES

- * Nmap scans are one of the most common reconnaissance techniques.
- * Detecting early helps prevent attackers from moving further.
- * Always investigate the source, intent and impact.
- * Combine Suricata alerts with other logs for better context.



ALERT TRIAGE WORKFLOW

Page 13 of 15

blueteamers.io

Once an alert is generated, the SOC analyst must triage and investigate it to determine if it is legitimate, malicious, or benign.

1. SOC ALERT TRIAGE WORKFLOW



2. EXAMPLE ALERT (EVE.JSON)

```
1 {
2   "timestamp": "2024-05-07T02:20:15.123456+0000",
3   "flow_id": 1234567890123456,
4   "event_type": "alert",
5   "src_ip": "10.0.0.5",
6   "src_port": 49752,
7   "dest_ip": "10.0.0.20",
8   "dest_port": 22,
9   "proto": "TCP",
10  "alert": {
11    "action": "allowed",
12    "gid": 1,
13    "signature_id": 1000003,
14    "rev": 1,
15    "signature": "ET SCAN Nmap Scripting Engine User-Agent Detected",
16    "category": "Attempted Information Leak",
17    "severity": 2
18  },
19  "flow": {
20    "state": "established",
21    "pkts_toserver": 4, "pkts_toclient": 2,
22    "bytes_toserver": 384, "bytes_toclient": 120
23  }
24 }
```

3. ALERT FIELD EXPLANATION

- ① Timestamp : When the alert was generated (UTC time).
- ② Source IP : IP of the system that initiated the connection.
- ③ Source Port : Port used by the source.
- ④ Destination IP : IP of the target host.
- ⑤ Destination Port : Port of the target service.
- ⑥ Protocol : Network protocol (TCP, UDP, ICMP, etc.).
- ⑦ Signature / Rule : The Suricata rule that matched.
- ⑧ Signature ID (SID) : Unique ID of the rule.
- ⑨ Category : Type of threat or activity.
- ⑩ Severity : How serious (1=Low, 2=Medium, 3=High, 4=Crit).
- ⑪ Action : What Suricata did (allowed / blocked / dropped).

4. ANALYST INVESTIGATION PROCESS



Key Questions to Ask

- Who generated this traffic?
- What was targeted?
- Is this activity expected or authorized?
- Is the source IP internal or external?
- Has this source been seen before?
- Is this part of a larger attack pattern?

Investigation Steps

- ① Review alert details in eve.json.
- ② Check source IP reputation (VirusTotal, AbuseIPDB, etc.).
- ③ Run WHOIS / RDNS lookup.
- ④ Check historical alerts from the same IP.
- ⑤ Correlate with other logs (Firewall, WAF, OS logs).
- ⑥ Determine intent and impact.

5. REAL WORLD EXAMPLE

Scenario

Multiple Nmap scans detected from 10.0.0.5 targeting 10.0.0.20 (SSH, HTTP, HTTPS). Suricata rule ET SCAN Nmap Scripting Engine User-Agent Detected matched.



Attacker
10.0.0.5

Nmap Scan



Target
10.0.0.20

Analyst Findings

- ✓ Source IP is internal.
- ✓ Multiple ports scanned.
- ✓ Nmap User-Agent detected.
- ✓ No business justification found.
- ✓ Similar activity seen 5 times in the last 10 minutes.

Conclusion

- ✓ True Positive
- ✓ Severity: Medium (2)
- ✓ Activity: Reconnaissance
- ✓ Action: Escalate



6. TRIAGE OUTCOME GUIDE

Outcome	Description	Example	Action
✓ True Positive	Malicious or suspicious activity that requires action.	Nmap scan, brute force attempt, exploit attempt.	Escalate to Incident Response. Block IP / Isolate if needed.
? Benign / Expected	Legitimate activity that is expected in the environment.	Vulnerability scan by Security Team.	Document and close. Create whitelist if needed.
✗ False Positive	Alert triggered but no real threat or incorrect match.	Legitimate tool triggering the rule.	Tune rule or adjust threshold. Document and close.

7. TRIAGE TIPS



- ✓ Always read the full alert.
- ✓ Context is everything.
- ✓ Correlate before escalating.
- ✓ Use multiple sources.
- ✓ Document your decision.

NOTES

- * Not every alert is an incident.
- * Good triage reduces noise.
- * Focus on patterns, not single events.
- * Investigate before you conclude.
- * Your decision impacts the SOC!

REMEMBER



Most SOC work is investigation, not detection.



★ Good analysts don't just see alerts. They understand stories behind them. ★

blueteamers.io

FROM ALERT TO RESPONSE

Page 14 of 15

blueteamers.io

Detecting a threat is only the first step. The SOC analyst must respond quickly, contain the risk, and help the organization recover safely.

1. INCIDENT RESPONSE WORKFLOW



2. REAL SCENARIO

Multiple Nmap scans detected from unknown IP 10.0.0.5 targeting internal host 10.0.0.20.

The activity is repeated several times within 10 minutes.
The SOC analyst investigates and responds.

3. ALERT OVERVIEW (EVE.JSON)

```
1 {
2   "timestamp": "2024-05-07T02:20:15.123456+0000",
3   "flow_id": 1234567890123456,
4   "event_type": "alert",
5   "src_ip": "10.0.0.5",
6   "src_port": 49752,
7   "dest_ip": "10.0.0.20",
8   "dest_port": 22,
9   "proto": "TCP",
10  "alert": {
11    "action": "allowed",
12    "gid": 1,
13    "signature_id": 1000003,
14    "signature": "ET SCAN Nmap Scripting Engine User-Agent Detected",
15    "category": "Attempted Information Leak",
16    "severity": 2
17  }
18 }
```

4. INVESTIGATION NOTES

- Source IP (10.0.0.5) is an internal host.
- Multiple ports scanned (22, 80, 443, 3306, 8080).
- Nmap User-Agent detected.
- No business justification found for scanning.
- Similar activity seen 5 times in the last 10 minutes.
- Classified as suspicious reconnaissance activity.



Analysis Summary

This appears to be unauthorized scanning activity.
Potential attacker trying to discover open ports and services.

5. TIMELINE OF ACTIVITY (FROM EVE.JSON)

Time (UTC)	Source IP	Destination IP	Signature / Event	Destination Port
02:18:44	10.0.0.5	10.0.0.20	Nmap Scan Detected	22
02:18:53	10.0.0.5	10.0.0.20	Nmap Scan Detected	80
02:19:05	10.0.0.5	10.0.0.20	Nmap Scan Detected	443
02:19:17	10.0.0.5	10.0.0.20	Nmap Scan Detected	3306
02:20:15	10.0.0.5	10.0.0.20	Nmap Scripting Engine UA	22

6. INCIDENT RESPONSE ACTIONS TAKEN



7. INCIDENT TICKET (EXAMPLE)

Ticket ID : INC-2024-0507-00125
Title : Multiple Nmap Scans Detected
Severity : Medium
Status : In Progress
Reported By : Suricata IDS
Source IP : 10.0.0.5
Destination : 10.0.0.20
First Seen : 2024-05-07 02:18:44 UTC
Last Seen : 2024-05-07 02:20:15 UTC
Description : Multiple Nmap scans detected from internal host. Ports 22, 80, 443, 3306, 8080 targeted. Nmap Scripting Engine User-Agent detected.
Actions Taken : IP Blocked, Team Notified, Monitoring Enabled
Owner : SOC Analyst
Next Review : 2024-05-07 10:00:00 UTC

8. RESPONSE SUMMARY

- ✓ Alert validated and confirmed as suspicious.
- ✓ Source IP blocked to prevent further scanning.
- ✓ No business justification found.
- ✓ Activity classified as malicious reconnaissance.
- ✓ Monitoring and logging increased.
- ✓ Incident documented for future reference.



9. KEY TAKEAWAYS

- * Fast detection + investigation = reduced risk.
- * Contain quickly to stop the attacker.
- * Documentation helps improve future response.
- * Every incident is a learning opportunity.
- * Teamwork and communication are critical.



ANALYST TIP

Always validate before escalating.
Context is everything!
Not every alert is an incident.



REMEMBER

Detection is only the beginning.
Your response makes the difference.



NOTES

Keep learning. Keep improving.
Stay curious. Stay sharp.
You are the defender!



☆ Great analysts respond today and build a stronger defense for tomorrow. ☆

blueteamers.io

IDS/IPS MASTER CHEAT SHEET

Page 15 of 15

blueteamers.io

Quick reference guide for SOC Analysts – Detect, Investigate, Respond, Improve.

1. IDS vs IPS

IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
✓ Monitors traffic ✓ Detects threats ✓ Alerts only ✓ Passive mode ✓ No traffic blocking	✓ Monitors traffic ✓ Detects threats ✓ Blocks threats ✓ Active mode ✓ Can stop attacks
i IDS = Observe & Detect IPS = Detect & Prevent	

2. NIDS vs HIDS

NIDS	HIDS
 • Monitors network traffic • Deployed on network sensors • Sees many hosts • Example: Suricata	 • Monitors host activity • Deployed on endpoints • Sees one host • Example: Wazuh

3. Signature vs Anomaly

Signature Based	Anomaly Based
 • Uses known patterns (signatures/rules) • High accuracy • Low false positives • Cannot detect new threats	 • Uses behavior baselines • Can detect unknown threats • Higher false positives • Needs tuning

4. DETECTION TYPES

	Malware Detection Detect malicious payloads and file activity.
	Network Scanning Detect port scans, host discovery, enumeration.
	Brute Force Attacks Detect repeated failed login attempts.
	Web Attacks Detect SQLi, XSS, LFI, RFI, etc.

5. SURICATA ESSENTIAL COMMANDS

```
# Check Suricata configuration
suricata -T

# Start Suricata (IDS mode)
suricata -c /etc/suricata/suricata.yaml
-i eth0

# Test rules
suricata -T -c /etc/suricata/suricata.yaml

# View alerts in real-time
tail -f /var/log/suricata/eve.json

# View fast alerts (alert log)
tail -f /var/log/suricata/fast.log

# Update rules (if using oinkmaster)
oinkmaster -u /etc/suricata/rules

# Check Suricata version
suricata --build-info

# Validate YAML configuration
suricata --dump-config -c suricata.yaml
```

6. ALERT INVESTIGATION STEPS

- 1 Read the Alert
Review timestamp, signature, source, destination, ports.
- 2 Validate the Source
Check Source IP reputation (VirusTotal, AbuseIPDB, etc.).
- 3 Gather Context
Check related logs (Firewall, WAF, OS, Proxy, DNS).
- 4 Correlate
Look for similar alerts and patterns in time window.
- 5 Assess Impact
What is being targeted? Any successful exploitation?
- 6 Determine Severity
Low, Medium, High, Critical.
- 7 Decide Action
True Positive → Escalate / False Positive → Tune rule.
- 8 Document
Document findings, decisions, and evidence.

7. COMMON ALERT CATEGORIES

Category	Examples
	Reconnaissance Nmap scans, port scans, host discovery
	Access Attempts Brute force, login attempts, exploitation
	Malware Malware download, C2 traffic, infected files
	Web Attacks SQL Injection, XSS, LFI, RFI
	Policy Violations Unauthorized software, data exfiltration
	DoS / DDoS SYN flood, UDP flood, ICMP flood

8. SURICATA LOG FILES

File	Purpose	Format	Notes
eve.json	Alerts & Events	JSON	Main log for analysis
fast.log	Alert Summary	Text	Quick alerts view
http.log	HTTP Transactions	Text	Web traffic logs
dns.log	DNS Transactions	Text	DNS query/response
tls.log	TLS/SSL Logs	Text	Encrypted traffic info
files.log	File Extracted	Text	Files captured
stats.log	Statistics	Text	Performance stats

9. ALERT PRIORITY GUIDE

Severity	Level	Color	Action
1	Low	Green	Monitor
2	Medium	Yellow	Investigate
3	High	Orange	Respond
4	Critical	Red	Immediate Response

10. SOC WORKFLOW

	Monitor Collect and monitor logs & alerts
	Detect Alerts triggered by rules/behavior
	Investigate Analyze alerts and gather evidence
	Respond Contain, eradicate, and mitigate
	Improve Tune rules, update detections, learn and improve

11. SOC ANALYST ROADMAP

1. Learn Fundamentals
Networking, OS, Security Basics
2. IDS/IPS (Suricata)
Detection, Rules, Alerts
3. Endpoint Security (Wazuh)
HIDS, Log Collection, Monitoring
4. SIEM (Splunk / ELK)
Centralized Logging & Correlation
5. Threat Hunting
Proactive Threat Discovery
6. SOC Analyst
Monitor, Detect, Investigate, Respond

12. ANALYST CHECKLIST

- ✓ Understand the alert completely.
- ✓ Verify source and destination.
- ✓ Check reputation of IPs/URLs.
- ✓ Correlate with other logs.
- ✓ Identify attack type and impact.
- ✓ Determine if True Positive.
- ✓ Escalate or create incident ticket.
- ✓ Document everything.
- ✓ Follow up and monitor.
- ✓ Close the loop.

13. USEFUL RESOURCES

- Suricata Documentation
<https://suricata.io/docs>
- Emerging Threats Rules
<https://rules.emergingthreats.net>
- Wazuh Documentation
<https://documentation.wazuh.com>
- AbuseIPDB
<https://www.abuseipdb.com>
- VirusTotal
<https://www.virustotal.com>

“ Detection finds the threat. Investigation reveals the story. Response stops the impact. ”